BOLT

Reconnaissance

Google: Bolt CMS is an open-source, flexible, and fast content management system (CMS) written in PHP and built on the Symfony framework.

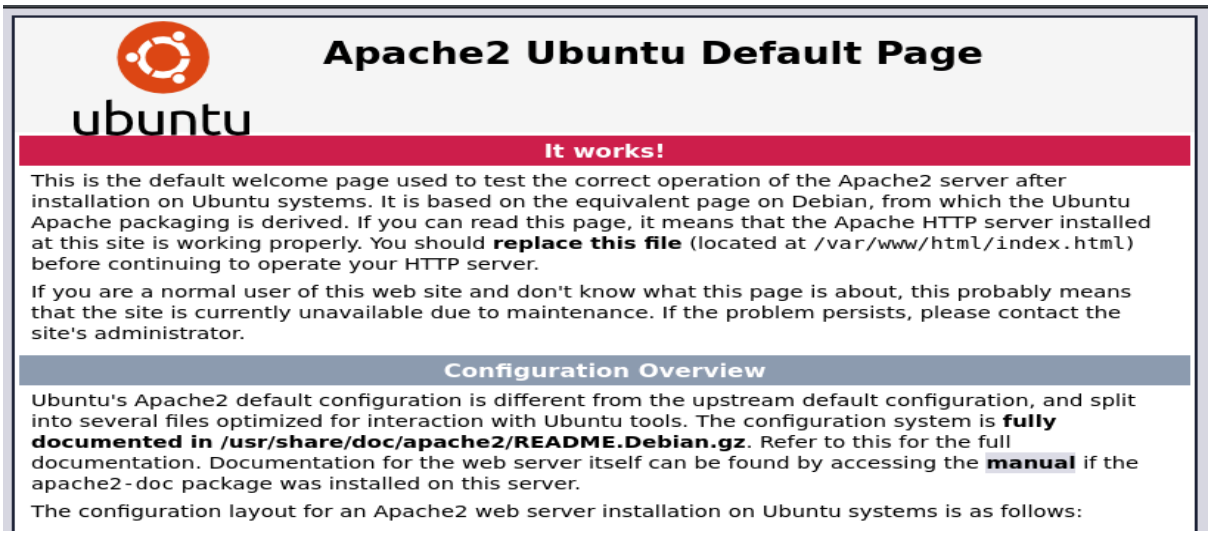
Uses **Twig** Template.

Scanning & Enumeration

Nmap scan: Found 3 ports open on our target.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sS 10.48.143.204
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-23 00:07 -0400
Nmap scan report for 10.48.143.204
Host is up (0.040s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
8000/tcp open  http-alt
```

port 80: Apache2 Default page found.



port 8000: found bolt cms running.

Credential:

Username as bolt

Password as boltadmin123

Hey guys,

i suppose this is our secret forum right? I posted my first message for our readers today but there seems to be a lot of freespace out there. Please check it out! my password is boltadmin123 just incase you need it!

Regards,

Jake (Admin)

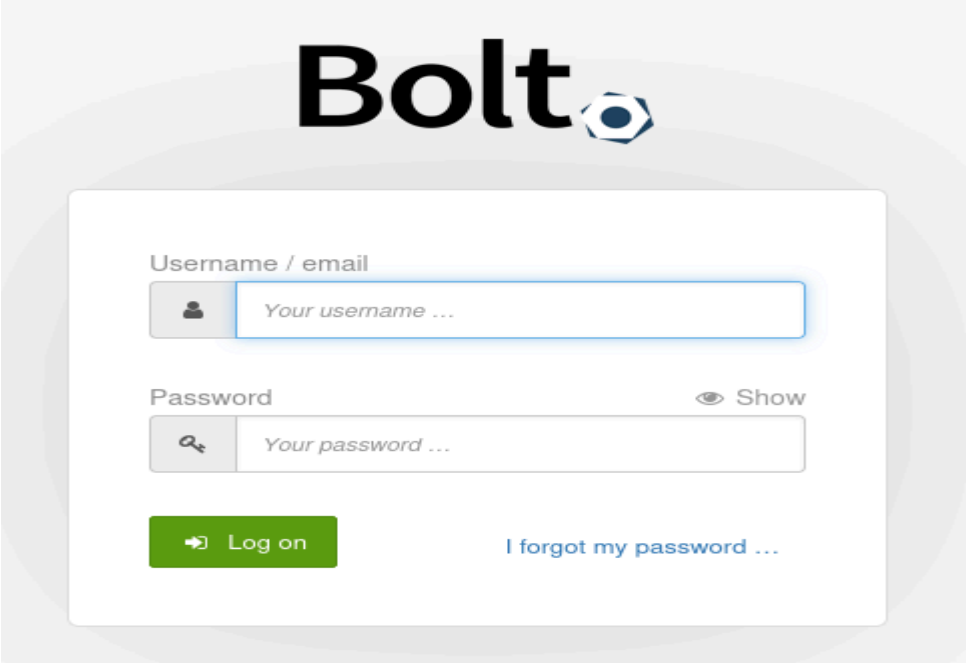
Hello Everyone,

Welcome to this site, myself Jake and my username is bolt. I am still new to this CMS so it can take awhile for me to get used to this CMS but believe me I have some great content coming up for you all!

Regards,

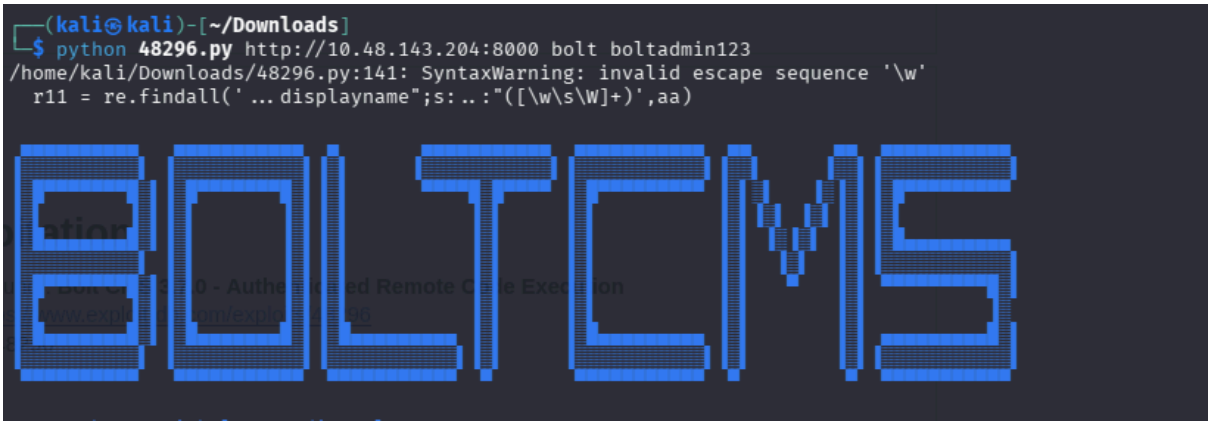
Jake (Admin)

Login page: http://10.48.143.204:8000/bolt/login



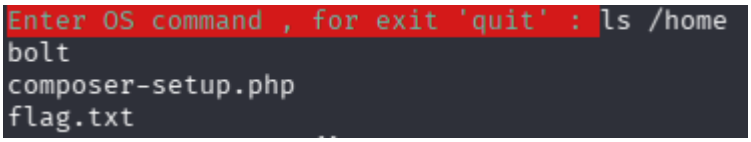
Exploitation

Exploit Found : **Bolt CMS 3.7.0 - Authenticated Remote Code Execution**
Link : https://www.exploit-db.com/exploits/48296
EDB-ID: 48296



Msfconsole path : **exploit/unix/webapp/bolt_authenticated_rce**

Post Exploitation



Flag:THM{wh0_d035nt_l0ve5_b0l7_r1gh7?}

Question and Answer

What port number has a web server with a CMS running?

8000

What is the username we can find in the CMS?

bolt

What is the password we can find for the username?

boltadmin123

What version of the CMS is installed on the server? (Ex: Name 1.1.1)

Bolt 3.7.1

There's an exploit for a previous version of this CMS, which allows authenticated RCE. Find it on Exploit DB. What's its EDB-ID?

48296

Metasploit recently added an exploit module for this vulnerability. What's the full path for this exploit? (Ex: exploit/....)

exploit/unix/webapp/bolt_authenticated_rce

Note: If you can't find the exploit module its most likely because your metasploit isn't updated. Run `apt update` then `apt install metasploit-framework`

Set the LHOST, LPORT, RHOST, USERNAME, PASSWORD in msfconsole before running the exploit

done

Look for flag.txt inside the machine.

Flag:THM{wh0_d035nt_l0ve5_b0l7_r1gh7?}